Fase 2 — Progettazione dello Scenario di Attacco (Spear-Phishing)

Data: 6 novembre 2026
Operatore: Elia F.
Ambito: Progettazione di uno scenario di spear-phishing

1. Obiettivo della fase

Definire un pretesto di attacco **strettamente personalizzato** sul target, costruito sui dati OSINT verificati in Fase 1, e specificare:

- il **contesto** (mittente fittizio credibile),
- l'**obiettivo** operativo dell'email,
- i **postulati di Cialdini** attivati e come vengono concretizzati nel testo.

Un buon spear-phishing differisce dal phishing generico perché il pretesto non è inventato "a caso": ogni elemento dell'email deve essere **ancorato a un fatto pubblico, verificabile e recente** del target. In questo modo la vittima (o il suo staff) non trova "smagliature" che facciano crollare la credibilità.

2. Analisi dei punti di aggancio (da Fase 1)

Dalla raccolta OSINT emergono i "filoni" realistici su cui costruire il pretesto:

Filino OSINT	Fatto (Fase 1)	Opportunità di pretesto
Touring	*Radical Optimism World Tour* 2023–2024, date sold out	**Insediamenti finanziari / royalties / stipuli tour** — flussi di denaro reali e frequenti
Etichetta	Contratto con **Warner Music UK**	Comunicazione "ufficiale" tramite canali di label/management

Filino OSINT	Fatto (Fase 1)	Opportunità di pretesto
Brand	Campagne L'Oréal, Fenty Beauty	Logistica spedizioni campioni / approvazione contenuti — plausibile ma meno "calda"
Ruolo istituzionale	Ambasciatrice **UN Women**	Inviti a eventi/gala — forte leva di autorità
Collaborazioni	Harris, Angèle, Missy Elliott, Nicki Minaj	"Sessioni" e produzioni — meno adatto a un obiettivo finanziario

Criterio di selezione: il pretesto più credibile e "caldo" è quello che unisce (a) un flusso economico reale e frequente, (b) un interlocutore organizzativo plausibile, (c) una scadenza naturale. → **Scelto: il filone touring / insediamento finanziario (royalties e spese tour).**

3. Contesto — Il mittente fittizio

- **Identità del mittente:** ***Meridian Touring Partners Ltd.*** — società fittizia, presentata come **partner logistico-finanziario esterno** incaricato dal management dell'artista dell'**insediamento (settlement) finanziario** delle tappe europee del tour.
- **Mittente operativo:** `settlements@meridiantouring-partners.com` (dominio fittizio; in esercizio reale si usa sempre un dominio di test).
- **Perché è credibile (e non è la "banca" generica):**
  1. **Ancoraggio al dato OSINT:** il target ha un ciclo di touring attivo e documentato (Fase 1, §4.2 e §4.5). Le tournee producono **insediamenti periodici** con etichetta, promoter e artisti: lo staff artistico *aspetta* comunicazioni di questo tipo, quindi l'email arriva "in un momento in cui ha senso" (fattore timing).
  2. **Ruolo plausibile:** le tournee reali esternalizzano spesso la parte finanziaria a società di *touring services*; un nome sconosciuto ma istituzionale è più credibile di un'agenzia bancaria generica, perché "parla il linguaggio" del contesto (settlement, invoice, rider, box office).
  3. **Personalizzazione:** il testo cita esplicitamente il nome del tour (*Radical Optimism World Tour*), il mercato (tappa europea) e la fase (chiusura insediamento). Sono dettagli che un phishing generico non avrebbe.
  4. **Posizione nella catena fiduciaria:** il mittente si inserisce dove lo staff *già opera* (etichetta/management), riducendo lo scetticismo rispetto a un mittente esterno "a freddo".

> **Regola di design:** il mittente fittizio non deve *copiare* un ente reale (Warner, UN Women) — quello creerebbe falsi positivi di credibilità e problemi legali — ma deve occupare **lo stesso ruolo organizzativo** che gli enti reali occupano nel flusso.

4. Obiettivo dell'email

Obiettivo primario — Esfiltrazione di credenziali:
indurre la vittima a inserire **credenziali di accesso** (email/management portal) in un falso portale di autenticazione ("Meridian Secure Portal") per firmare la dichiarazione di insediamento. Le credenziali catturate (credential harvesting) aprono accesso a email, calendari e portali gestionali da cui derivare dati ulteriori.

Obiettivo secondario — Raccolta di dati finanziari:
il form di "verifica del conto" chiede **IBAN, intestatario, riferimenti fatturazione** per l'"accredito" del settlement: dati che in un attacco reale alimentano un piano di **fraude alle fatture (BEC — Business Email Compromise)**.

Variante di fallback — Infezione tramite allegato (opzionale, per confronto):
invece del link, l'email allega il `Settlement_Statement_EU_Q4.pdf` con una **macro attivabile** (o un exploit del viewer PDF) che scarica un beacon verso il C2. Questa variante è utile nell'esercizio per mostrare la differenza di rischio **link (credential harvesting)** vs **allegato (payload)** e per addestrare il riconoscimento di entrambi i pattern.

Obiettivo NON dichiarato (disciplinare): nessun obiettivo di distruzione, furto di identità o danneggiamento — l'intero scenario è misurabile e reversibile in ambiente di test (es. credential trap su dominio controllato).

5. Postulati di Cialdini — Leve psicologiche attivate

#	Leva di Cialdini	Come è concretizzata nell'email	Segnale di riconoscimento (per la difesa)
1	**Urgenza**	Scadenza di **48 ore** per la firma della dichiarazione; altrimenti "lo settlement slitta al trimestre successivo" con conseguente ritardo dei pagamenti allo staff	Il vincolo temporale è artificioso e sproporzionato a un'operazione di routine; una richiesta reale di

#	Leva di Cialdini	Come è concretizzata nell'email	Segnale di riconoscimento (per la difesa)
			settlement non "scade" in 48h
2	**Autorità**	Tono legale-amministrativo, riferimenti a numeri di contratto, nomi di ruoli (Touring Finance Director), linguaggio da compliance; si inserisce nella catena fiduciaria label/management già nota al target	Verifica del mittente fuori dalla catena nota; il "linguaggio ufficiale" non sostituisce l'identità verificata del dominio
3	**Scarsità**	"Ultimo promemoria prima dell'archiviazione della dichiarazione" — la finestra di azione si chiude	L'artificiosità della "finestra che si chiude" su un documento amministrativo che può essere rifirmato in qualsiasi momento
4	**Reciprocità** (secondaria)	Menzione di un "accredito in sospeso" a favore dell'artista: il mittente "dà" (paga) e chiede in cambio solo la firma	Un beneficio concreto ma non verificabile, usato come moneta di scambio per la collaborazione
5	**Coerenza/Impegno** (secondaria)	Richiama "la procedura già adottata nelle tappe precedenti del tour", costringendo la vittima a mantenere coerente il comportamento passato	Appello alla routine: la richiesta è presentata come ripetizione di un'abitudine, non come evento nuovo

Leve NON usate (e perché): *Simpatia* e *Prova Sociale* sono volutamente escluse perché richiedono una relazione personale pregressa che lo staff del target non ha con il mittente; forzarle produrrebbe smagliature. La combinazione **Urgenza + Autorità + Scarsità** è il nucleo del pretesto; Reciprocità e Coerenza sono rinforzi secondari.

6. Sequenza d'attacco (kill chain semplificata)

```
[1. Riconoscimento]     Dati OSINT Fase 1 (tour, etichetta, flussi finanziari)
        |
[2. Pretesto]           Mittente fittizio "Meridian Touring Partners" (ruolo finanzi
        |
[3. Innesco]            Email "chiusura settlement tappa EU" + scadenza 48h (Urgenza
        |
[4. Interazione]        CTA: "Firma la dichiarazione" → falso login (autorità + scar
        |
[5. Esfiltrazione]      Credenziali + dati IBAN → credential harvesting / BEC setup
        |
[6. Post-esfiltrazione] (fuori scope didattico) accesso a mailbox/portal → escalatio
```

In ambiente di test, il passo [5] termina su un **credential trap**: il form POSTa su un dominio di test controllato, che registra e scarta le credenziali. Non c'è persistenza né movimento laterale: l'esercizio è **misurabile e reversibile**.

7. Modello dimostrativo dell'email

Da: `settlements <settlements@meridiantouring-partners.com>`
Oggetto: `ACTION REQUIRED — Radical Optimism World Tour: EU settlement sign-off (48h)`

```
Dear Dua,

Following the conclusion of the European legs of the Radical Optimism
World Tour, we are finalising the quarterly settlement statement for the
tour's European window.

Our records show that the EU settlement (ref. MTP-2026-EU-0417) is now
awaiting artist sign-off. In line with the procedure adopted for the
preceding legs, the statement must be countersigned before we release
the outstanding balance to the tour accounts.

Please note: if the sign-off is not received within the next 48 hours,
the statement will be archived for the current cycle and the release
will roll over to the next quarterly window, which will delay the
tour's outstanding payments.

To countersign:
   1. Open the Meridian Secure Portal (link below) and sign in with
      your management email credentials.
```

```
   2. Review statement MTP-2026-EU-0417 and countersign.
   3. Confirm the receiving account details shown, so the release is
      credited to the correct tour account.

[ Countersign settlement (48h window) ]  →  https://secure-portal.example-test/…

If you have already countersigned this statement, please disregard this
notice.

Kind regards,
R. Calloway
Touring Finance Director
Meridian Touring Partners Ltd.
settlements@meridiantouring-partners.com
```

Mappa leva → frase (per l'analisi in aula):

Leva (Cialdini)	Frase nel modello
Urgenza	"…within the next 48 hours… the release will roll over…"
Autorità	"Touring Finance Director", "ref. MTP-2026-EU-0417", "in line with the procedure adopted…"
Scarsità	"…will be archived for the current cycle…" (finestra che si chiude)
Reciprocità	"…we release the outstanding balance…" (beneficio in sospeso)
Coerenza	"…in line with the procedure adopted for the preceding legs…"
Personalizzazione OSINT	"Radical Optimism World Tour", "European legs", "tour's outstanding payments"

Indicatori di phishing (IOI — per addestrare il riconoscimento):

- dominio mittente sconosciuto nella catena fiduciaria nota (non label, non management);
- urgenza artificiosa (48h) su un'operazione che non ha scadenza naturale;
- CTA a inserire credenziali in un portale "esterno" per un'operazione amministrativa;
- richiesta di confermare dati IBAN in una fase inusuale;
- tono da "procedura già adottata" per sfruttare la routine;

- invariata la firma: **mai** inserire credenziali di management in un form di un dominio non verificato.

8. Perché lo scenario è "strettamente personalizzato"

Ogni elemento del pretesto è **tracciabile** a un dato OSINT di Fase 1:

Elemento dell'attacco	Dato OSINT di origine (Fase 1)
Nome del tour citato	§4.2 — *Radical Optimism World Tour* 2023–2024
Focus "tappa europea"	§4.2 — tour con date in Europa (sold out)
Flusso finanziario atteso	§4.2/§4.5 — touring attivo con flussi di insediamento reali
Lingua e mercato (UK/EN)	§4.1/§4.6 — base Londra, Warner Music UK
Ruolo del mittente	§4.6 — catena organizzativa label/management/touring
Momento di invio (timing)	§4.5 — attività discografica e touring in corso

La personalizzazione non è "ciao + nome": è **contesto, timing e linguaggio** presi dalla vita professionale reale e pubblica del target. È questo che distingue lo spear-phishing dal phishing generico ed è il punto didattico centrale della Fase 2.

9. Difesa (cosa deve riconoscere la vittima / lo staff)

1. **Verifica dell'identità del mittente** fuori-banda (telefono di management/etichetta noto) prima di qualsiasi CTA.
2. **Contesto anomalo** = segnale: un "settlement" con scadenza 48h non è una procedura standard.
3. **Mai inserire credenziali** di management/etichetta in un dominio non appartenente alla catena fiduciaria verificata.
4. **Checklist IOI** (§7) applicata a ogni email che combina urgenza + autorità + CTA di autenticazione.
5. **Procedura di segnalazione** interna (report al team IT/sicurezza) invece di cliccare.